MunichTech GmbH

INFORMATION SECURITY MANAGEMENT SYSTEM

NIS2 Incident Reporting Workflow

Document Reference	MT-NIS2-IRP-001
Version	1.3
Effective Date	21 October 2026
Prepared By	Austin Bond, Junior GRC Consultant
Reviewed By	Dr. Andreas Kellermann, CISM, ISO LA
Approved By	CEO / Managing Director, MunichTech GmbH
Confidentiality Level	**CONFIDENTIAL** — Internal Use Only

Version	*Date*	*Author*	*Change Description*
1.0	5 November 2025	Austin Bond	Initial workflow creation; aligned with § 32 BSIG (NIS2 Art. 23) and DSGVO reporting timelines
1.1	14 January 2026	Austin Bond	Currency update: reporting obligations restated as Sec. 32 BSIG, executive accountability as Sec. 38 BSIG, and entity classification as wichtige Einrichtung under Sec. 28(2) BSIG.
1.2	3 March 2026	Austin Bond	Citation correction: BaFin BAIT in the interested-party table replaced with DORA (Reg. (EU) 2022/2554), applicable from 17 January 2025. No reporting timeline, threshold or escalation path changed.
1.3	21 October 2026	Austin Bond	Entity classification corrected: the withdrawn Einrichtungsart "IKT-Dienstleistungsmanagement (B2B)" replaced by Anlage 1 Nr. 6.1.4 (Anbieter von Cloud-Computing-Diensten) in the purpose statement. No reporting threshold, timeline or escalation path changed.

Table of Contents

1. Purpose and Scope
2. Trigger: Definition of "Awareness" and "Significant Incident"
3. The 24–72–30 Reporting Timeline
4. Parallel Reporting Obligations (The "Double Notification" Rule)
5. Executive Accountability (§ 38 BSIG / NIS2 Art. 20)
6. Document Sign-Off

1. Purpose and Scope

This document defines the standard operating procedure (SOP) and mandatory reporting workflow for MunichTech GmbH in the event of a significant cyber security incident. As a wichtige Einrichtung (BSIG § 28(2), Anlage 1 Nr. 6.1.4) supplying cloud-computing services to the financial sector, MunichTech GmbH is legally obligated under § 32 BSIG to adhere to strict 24-hour, 72-hour, and 1-month reporting deadlines to the Federal Office for Information Security (Bundesamt für Sicherheit in der Informationstechnik - BSI).

This workflow applies to the IT Security Lead, Head of Engineering, Legal Counsel, and the Executive Management Team.

2. Trigger: Definition of "Awareness" and "Significant Incident"

The regulatory clock does not start when a generic SIEM alert fires. The clock starts at the moment of Awareness — defined as the point when the incident response team has a reasonable degree of certainty that a "Significant Incident" has occurred based on initial assessment.

Under NIS2, an incident is classified as Significant if it meets either of the following thresholds:

- Operational/Financial Impact: It has caused, or has the potential to cause, severe operational disruption to the MunichTech SaaS platform (violating client SLAs) or severe financial loss.
- Third-Party Damage: It has affected, or is capable of affecting, other natural or legal persons (e.g., enterprise banking clients) by causing considerable material or non-material damage.

If an event is assessed as a Significant Incident by the IT Security Lead, the CEO and Legal Counsel must be notified within 15 minutes, and the following 24-72-30 timeline is immediately activated.

2.1 Near Misses: Internal Triage Only

Not every security event is an incident, and not every incident is notifiable. The BSIG defines a near miss (Beinahevorfall, § 2 Nr. 1 BSIG) as an event that could have compromised the availability, integrity or confidentiality of information but did not, and distinguishes it from an erheblicher Sicherheitsvorfall, meaning a significant incident within the meaning of § 32 BSIG. The distinction decides what is owed to whom: § 32 BSIG obliges MunichTech GmbH to notify the BSI only of significant incidents, so a near miss triggers no notification duty, no 24-hour clock and no report to any authority.

Near misses are nevertheless recorded and triaged, because a narrowly avoided outage is the cheapest evidence an ISMS gets, and discarding it for want of a reporting duty would be a self-inflicted blind spot. The branch below is internal only.

Step 1, log. Any employee, and any automated control that fires and then clears, raises the event in Jira Service Management as a near miss against the affected asset in the Information Asset Register (MT-ISMS-IAR-001). The reporting channel is the one already used for incidents, so nobody has to decide first whether an event qualifies.

Step 2, triage. The IT Security Lead triages the entry within two business days against the two significance thresholds in Section 2 and records the outcome. Triage is internal; no external party is involved at this stage.

Step 3, reclassify where a threshold is met. If triage shows that the event did, or could have, met a significance threshold, it is reclassified as a Significant Incident and the workflow in Section 3 applies in full. The 24-hour early warning is then due within 24 hours of the reclassification rather than of the original detection, because Awareness within the meaning of Section 2 is the point at which the response team has reasonable certainty that a Significant Incident has occurred. The 15-minute notification of the CEO and Legal Counsel described in Section 2 runs from that same point.

Step 4, learn. A near miss that was not reclassified is closed with a written root-cause note, and a Post-Incident Review under Annex A 5.27 is held where the same failure could plausibly recur. Corrective actions are tracked in Jira with an owner and a due date, and any change to a control is closed through MT-ISMS-CAP-001.

Step 5, feed back. The near-miss register is summarised monthly to the interim CISO and reported as a standing input to the Management Review (MT-ISMS-MRA-001). A severe near miss is a risk assessment trigger under Section 2 of the Risk Assessment Methodology (MT-ISMS-RAM-001).

Voluntary reports. Section 32 BSIG imposes no duty to report a near miss, but § 5 BSIG permits voluntary reports to the BSI. MunichTech GmbH does not report near misses as a matter of routine. Where the IT Security Lead and Legal Counsel decide that a voluntary report is warranted, for example because the near miss reveals a sector-wide attack pattern, the decision and its rationale are recorded in the near-miss entry. A voluntary report is never a substitute for a mandatory notification where one is due, and a near miss under this subsection is not an incident for the purposes of Section 3.

3. The 24–72–30 Reporting Timeline

3.1 Phase 1: The 24-Hour Early Warning

- **Deadline:** Without undue delay, and in any event within 24 hours of Awareness.
- **Recipient:** BSI (via the official BSI Reporting Portal).
- **Owner:** IT Security Lead (Approval by Legal Counsel).
- **Required Information:** A credible early warning indicating whether the incident is suspected of being caused by unlawful or malicious acts (e.g., ransomware) and whether it has the potential to have a cross-border impact across other EU Member States.

3.2 Phase 2: The 72-Hour Incident Notification

- **Deadline:** Without undue delay, and in any event within 72 hours of Awareness.
- **Recipient:** BSI.
- **Owner:** Head of Engineering (Approval by CEO).
- **Required Information:** Updates to the 24-hour early warning, an initial assessment of the incident's severity and business impact, identification of affected systems, initial containment measures deployed, and Indicators of Compromise (IoCs) where available.

3.3 Phase 3: Intermediate Reports

- **Deadline:** Upon specific request by the BSI or CSIRT.
- **Recipient:** BSI.
- **Required Information:** Relevant status updates on containment, ongoing recovery efforts, and newly discovered IoCs.

3.3 Phase 4: The 1-Month Final Report

- **Deadline:** Not later than one month after the submission of the 72-Hour Incident Notification. If the incident is still ongoing at 30 days, a Progress Report must be filed instead, with the Final Report due one month after the incident is fully closed.
- **Recipient:** BSI.
- **Owner:** CISO / Head of Engineering (Approval by CEO).
- **Required Information:** A detailed forensic description of the incident, its severity and total impact, the exact type of threat or root cause, applied and ongoing risk mitigation measures, and a final assessment of cross-border impacts.

4. Parallel Reporting Obligations (The "Double Notification" Rule)

A cyber incident at MunichTech GmbH may trigger parallel legal obligations. The Legal Counsel is responsible for managing the following concurrent workflows:

Regulatory Body	*Law / Regulation*	*Deadline*	*Trigger Condition*
BSI (Germany)	NIS2 (BSIG § 32)	24 Hours	Significant operational disruption or systemic risk.
BayLDA (Bavaria)	DSGVO (GDPR) Art. 33	72 Hours	The incident involves the accidental or unlawful destruction, loss, alteration, or unauthorized disclosure of personal data (e.g., client PII).
Enterprise Clients	Contracts / DORA	Immediate	The BSI orders MunichTech to inform clients, OR the incident directly impacts the provision of services to the client.

5. Executive Accountability (§ 38 BSIG / NIS2 Art. 20)

Under § 38 BSIG (NIS2 Art. 20), the management body (Managing Directors / CEO) of MunichTech GmbH must approve the cybersecurity risk-management measures and oversee their implementation.

Failure to adhere to this reporting workflow may result in administrative fines for the company, the temporary suspension of managerial responsibilities, and personal financial liability for the executive board. To satisfy this requirement, the CEO must explicitly sign off on the 72-Hour Incident Notification and the 1-Month Final Report prior to their submission to the BSI.

DOCUMENT APPROVAL

PREPARED BY	
Name	Austin Bond
Title	Junior GRC Consultant
Date	20 October 2026
Signature	
REVIEWED BY	
Name	Dr. Andreas Kellermann
Title	Senior GRC Partner, CISM | ISO 27001 Lead Auditor
Date	20 October 2026
Signature	
APPROVED BY	
Name	Dr. Katharina Vogt
Title	Chief Executive Officer, MunichTech GmbH
Date	21 October 2026
Signature	